

الوحدة 05: الهاش والتوقيع الرقمي

دوال الهاش (Hash Functions)

دالة الهاش هي دالة رياضية تأخذ بيانات بأي حجم وتخرج قيمة بطول ثابت (Fixed-length output). خصائصها:

- اتجاه واحد (One-way): لا يمكن استرجاع البيانات الأصلية من قيمة الهاش.
- مقاومة التصادم (Collision Resistant): من الصعب جداً إيجاد ملفين مختلفين لهما نفس قيمة الهاش.
- حتمية (Deterministic): نفس المُدخل يعطي دائماً نفس المُخرج.
- سرعة التغيير (Avalanche Effect): تغيير حرف واحد في الملف يغير قيمة الهاش بالكامل.

أنواع الهاش (Hash Algorithms)

- MD5: ينتج 128 بت (32 حرفاً). غير آمن - سهل التصادم. لا يُستخدم للأمان.
- SHA-1: ينتج 160 بت (40 حرفاً). يعتبر غير آمن منذ 2017. ممنوع في TLS.
- SHA-256: ينتج 256 بت (64 حرفاً). آمن ويُستخدم حالياً في Blockchain و TLS.
- SHA-3: أحدث معيار (2015). مبني على Keccak. آمن للغاية.

حساب هاش SHA-256 في Linux و Windows

في Linux:

```
sha256sum document.pdf
```

يقرأ الملف ويطبع قيمة الهاش (64 حرفاً) واسم الملف. تُستخدم للتحقق من أن الملف لم يتغير.

في Windows:

```
certutil -hashfile document.pdf SHA256
```

يقوم certutil بحساب SHA-256 للملف. يمكن أن يستغرق عدة ثوانٍ حسب حجم الملف.

في Python (bcrypt - تخزين كلمات المرور):

```
import bcrypt
password = b"MySecureP@ss123"
salt = bcrypt.gensalt()
hashed = bcrypt.hashpw(password, salt)
print(hashed)
# (حرفاً 64) b'$2b$12$LJ3m..' مثال :
```

- **bcrypt.gensalt():** يولد ملحاً عشوائياً (Salt).
- **bcrypt.hashpw():** يدمج كلمة المرور مع الملح ويطبق دالة الهاش.
- **bcrypt** مضمن ضد هجمات Brute Force لأنه بطيء عمداً (Key Stretching).

الملح والفلفل (Salt & Pepper)

الملح (Salt): قيمة عشوائية تُضاف إلى كلمة المرور قبل الهاش. تمنع هجمات Rainbow Tables لأن كل مستخدم يحصل على ملح مختلف.

الفلفل (Pepper): قيمة سرية ثابتة تُضاف قبل الهاش، لكنها لا تُخزن مع الهاش في قاعدة البيانات. تحمي حتى لو سُرقت قاعدة البيانات.

هجوم عيد الميلاد (Birthday Attack)

يعتمد على مفارقة عيد الميلاد: في مجموعة من 23 شخصاً، احتمال وجود شخصين بنفس تاريخ الميلاد أكبر من 50%. في التشفير، يعني أن إيجاد تصادم (ملفين بنفس الهاش) أسهل مما تظن. هجوم Birthday يقلل من جهد إيجاد التصادم من 2^n إلى $2^{n/2}$. لذا SHA-256 يعطي أمان 128 بت ضد هذا الهجوم (لأن $n=256 \rightarrow n/2=128$).

توسيع المفتاح (Key Stretching)

تقنية تجعل عملية الهاش أبطأ عمداً لمواجهة هجمات Brute Force. أمثلة:

- **bcrypt:** يستخدم Cost Factor (مثلاً $12 = 2^{12}$ جولة).
- **PBKDF2:** يطبق الهاش آلاف المرات (مثلاً 600,000 تكرار).
- **Argon2:** الفائز في مسابقة (PHC) 2015. يستخدم الذاكرة والمعالج معاً.

التوقيع الرقمي باستخدام openssl dgst

```
openssl dgst -sha256 -sign private.pem -out signature.bin document.pdf
```

- **dgst:** أمر لحساب الهاش والتوقيع.
- **-sha256:** يستخدم SHA-256 للهاش.
- **-sign private.pem:** يوقع باستخدام المفتاح الخاص.
- **-out signature.bin:** حفظ التوقيع في ملف.

```
openssl dgst -sha256 -verify public.pem -signature signature.bin document.pdf
```

للتحقق من التوقيع باستخدام المفتاح العام. إذا تطابق التوقيع $\Rightarrow$ الملف أصلي (لم يتغير) والمرسل موثوق.

(Quick Quiz (MCQ

?Which of the following is NOT a property of a cryptographic hash .1

- a) One-way function
- b) Fixed output length
- c) Reversible
- d) Collision resistant

Answer: c

?What is the purpose of a Salt in password hashing .2

- a) To speed up hashing
- b) To defend against Rainbow Table attacks
- c) To compress data
- d) To encrypt files

Answer: b

?What is a Birthday Attack .3

- a) A physical attack on a birthday
- b) Finding two inputs that produce the same hash
- c) A type of network scan
- d) A social engineering attack

Answer: b

:Key Stretching is used to .4

- a) Make keys shorter
- b) Make weak passwords harder to crack
- c) Decrypt data faster
- d) Generate random numbers

Answer: b

?Which OpenSSL command computes a digital signature .5

- a) openssl genrsa
- b) openssl enc
- c) openssl dgst -sign
- d) openssl req

Answer: c